

Metr / Murabba — Frontend API Guide (user-service + content-service)

Audience: mobile/web frontend

Date: 29 September 2026

Covers both backends: user-service (port 3000) and content-service (port 3001)

Postman: import `postman/Metr-API.postman_collection.json` (one collection for both services)

Also available as PDF: `docs/Metr-Frontend-API-Guide.pdf`

Base URLs (local):

Service	Port	Base URL
user-service (auth, profile, follow)	3000	<code>http://localhost:3000</code>
content-service (About, Help, Version, Languages, Contact)	3001	<code>http://localhost:3001</code>

Content-Type: `application/json` except photo upload (`multipart/form-data`).

Auth: Authorization: Bearer `<accessToken>` where marked JWT.

Admin CMS: header `x-admin-key: <ADMIN_API_KEY>` (content-service only).

Map UI copy to the `error` code, not HTTP status alone. User-facing text is always:

```
{
  "error": "OTP_INVALID",
  "message": { "en": "...", "ar": "..." }
}
```

Show `message.en` or `message.ar` from the user's language. Extra fields (`attemptsRemaining` , `lockedUntil` , `resendAvailableAt`) can sit next to `error` / `message` .

Nest class-validator (wrong JSON types, extra keys, bad phone pattern on DTO) returns a **different** 400 shape (`statusCode` , `message` array, `error: "Bad Request"`). That is not bilingual. Fix the request; do not map those strings into UI copy.

Route index

user-service `http://localhost:3000`

Auth	Method	Path	JWT
Health	GET	<code>/health</code>	no
Username available	GET	<code>/users/username/available?username=</code>	no
Sign up	POST	<code>/auth/signup</code>	no
Log in	POST	<code>/auth/login</code>	no

Auth	Method	Path	JWT
Verify OTP	POST	/auth/otp/verify	no
Resend OTP	POST	/auth/otp/resend	no
Me	GET	/auth/me	yes
Update profile	PATCH	/auth/me	yes
Upload photo	POST	/auth/me/photo	yes
Logout	POST	/auth/logout	yes
Delete account	DELETE	/auth/account	yes
Profile photo file	GET	/uploads/...	no
Search advertisers	GET	/users/search?q=&limit=&offset=	yes
Suggested advertisers	GET	/users/suggested?limit=&offset=	yes
User profile	GET	/users/:id	yes
Followers	GET	/users/:id/followers?limit=&offset=	yes
Following	GET	/users/:id/following?limit=&offset=	yes
Follow	POST	/users/:id/follow	yes
Unfollow	DELETE	/users/:id/follow	yes

Pagination: `limit` default **20**, max **50**; `offset` default **0**. `:id` is a UUID.

content-service <http://localhost:3001>

Screen	Method	Path
Health	GET	/health
About	GET	/about
Help Center	GET	/help
App Version	GET	/version
Languages	GET	/languages
Contact types	GET	/contact/types
Recovery OTP start	POST	/contact/recovery/otp/start
Recovery OTP verify	POST	/contact/recovery/otp/verify
Recovery OTP resend	POST	/contact/recovery/otp/resend
Submit Contact Us	POST	/contact

Admin CMS (header `x-admin-key`): collection + `GET/PATCH/DELETE /:id` on `/admin/about`, `/admin/help-pages`, `/admin/help-categories`, `/admin/help-items`, `/admin/versions`, `/admin/contact-types`, `/admin/language-pages`, `/admin/languages`.

What is implemented (and what is not)

Implemented

- Sign up / log in with OTP (6 digits, 2 min, 3 tries, 5 min lockout, 30s resend, max 3 resends)
- Username required, unique, 3–20 [A-Za-z0-9_-]+
- Phone E.164 (+9665...)
- JWT session, logout, delete account
- My profile header: photo, display name, username, city, bio
- Local photo upload (JPEG/PNG/WebP, max 5 MB)
- Language catalog (Arabic RTL / English LTR) — **choice is stored on the device**, not the server
- About, Help Center, App version
- Contact Us form
- Recover Deleted Account (guest): phone OTP then ACCOUNT_RECOVERY contact ticket
- Follow advertisers only; followers/following lists; search/suggestions = advertisers only
- Admin CRUD for About / Help / Version / Languages / contact types

Not implemented (do not call these)

- Liked videos tab / unlike
- Following **posts** feed
- Upgrade-to-advertiser API (isAdvertiser is DB-only for now)
- Automated account restore (support reviews recovery tickets manually)
- Soft-delete / 30-day eligibility API (support policy only)
- Change-mobile / CAPTCHA

Global rules

1. Do not send extra JSON keys (forbidNonWhitelisted).
2. Guest screens (About, Help, Version, Languages, Contact, health) need **no JWT**.
3. After login, send JWT on user-service profile/follow routes.
4. Pick en or ar from bilingual payloads using the language stored on the phone.
5. Photo URLs are relative: prefix with user-service base, e.g. http://localhost:3000 + photoUrl .
6. Unknown JWT → HTTP 401 (Nest default, not bilingual).

1. Sign up

- ```
1. GET /users/username/available?username=Murabaa-1837
2. POST /auth/signup
3. User enters 6-digit OTP (console if 4Jawaly is not configured)
4. POST /auth/otp/verify → accessToken + user
5. Save accessToken. Use it as Bearer token.
```

GET /users/username/available?username=

No auth.

**200** { "available": true | false }

**400** USERNAME\_INVALID

POST /auth/signup

```
{
 "phone": "+96651234567",
 "username": "Murabaa-1837",
 "acceptedTerms": true
}
```

**201**

```
{
 "sessionId": "uuid",
 "expiresAt": "2026-09-28T18:00:00.000Z",
 "resendAvailableAt": "2026-09-28T17:58:30.000Z",
 "attemptsRemaining": 3
}
```

| Code                     | HTTP | When                                            |
|--------------------------|------|-------------------------------------------------|
| TERMS_REQUIRED           | 400  | acceptedTerms is not true                       |
| USERNAME_INVALID         | 400  | bad username                                    |
| USERNAME_TAKEN           | 409  | username exists                                 |
| PHONE_ALREADY_REGISTERED | 409  | phone already has an account                    |
| OTP_LOCKED               | 429  | this phone is locked; body includes lockedUntil |

New users are **normal** ( isAdvertiser: false ). They cannot be followed and do not appear in search.

## 2. Log in

1. POST /auth/login { "phone": "+96651234567" }
2. POST /auth/otp/verify

**404** PHONE\_NOT\_REGISTERED if the number has no account.

## 3. OTP verify / resend

POST /auth/otp/verify

```
{ "sessionId": "uuid", "code": "123456" }
```

**201**

```
{
 "accessToken": "eyJ...",
 "user": {
 "id": "uuid",
 "username": "Murabaa-1837",
 "phone": "+96651234567",
 "displayName": null,
 "city": null,
 "bio": null,
 "photoUrl": null,
 "isAdvertiser": false
 }
}
```

Then call `GET /auth/me` for follow counts.

| Code              | HTTP | Extra                                            |
|-------------------|------|--------------------------------------------------|
| OTP_INVALID       | 400  | attemptsRemaining                                |
| OTP_EXPIRED       | 400  | code older than 2 minutes                        |
| OTP_LOCKED        | 429  | lockedUntil after 3 wrong codes (wait 5 minutes) |
| SESSION_NOT_FOUND | 404  | bad/consumed sessionId                           |

`POST /auth/otp/resend`

```
{ "sessionId": "uuid" }
```

Same shape as signup/login start.

**429** `OTP_RESEND_COOLDOWN` (wait 30s) or `OTP_RESEND_LIMIT` (max 3 resends) or `OTP_LOCKED`.

## 4. Session

All of these need JWT.

| Method | Path                       | Result                                      |
|--------|----------------------------|---------------------------------------------|
| GET    | <code>/auth/me</code>      | current user + follow stats                 |
| POST   | <code>/auth/logout</code>  | <code>{ "ok": true }</code> — token is dead |
| DELETE | <code>/auth/account</code> | <code>{ "ok": true }</code> — user deleted  |

`GET /auth/me`

```
{
 "id": "uuid",
 "username": "Murabaa-1837",
 "phone": "+96651234567",
 "displayName": "Mohammed Ahmed",
```

```

"city": "Riyadh",
"bio": "Real estate expert...",
"photoUrl": "/uploads/profiles/uuid.jpg",
"isAdvertiser": false,
"followersCount": 0,
"followingCount": 3,
"showFollowers": false,
"canBeFollowed": false
}

```

## How to render My Profile header

| Field          | UI                                                     |
|----------------|--------------------------------------------------------|
| photoUrl       | avatar; null → placeholder                             |
| displayName    | big name; if null, show username                       |
| username       | @username                                              |
| city           | location line                                          |
| bio            | Bio                                                    |
| followingCount | Following                                              |
| followersCount | hide if showFollowers is false, or show 0 not tappable |
| showFollowers  | Followers tab only if true (advertisers)               |

## 5. Edit profile

JWT.

**PATCH** /auth/me

Any subset:

```

{
 "displayName": "Mohammed Ahmed",
 "city": "Riyadh",
 "bio": "Real estate expert helping you find your dream home."
}

```

Empty string clears a field ( null ).

Max: name 80, city 80, bio 500.

**400** DISPLAY\_NAME\_INVALID / CITY\_INVALID / BIO\_INVALID

**POST** /auth/me/photo

multipart/form-data , field name **photo** . JPEG, PNG, or WebP. Max **5 MB**.

Returns the same user object as `GET /auth/me` (without follow stats).

Display image as `{userBaseUrl}{photoUrl}`.

**400** `PHOTO_REQUIRED` / `PHOTO_INVALID` / `PHOTO_TOO_LARGE`

---

## 6. Language (content-service)

**Persist the choice on the phone** (SharedPreferences / UserDefaults). Do not POST it to the API.

`GET http://localhost:3001/languages` **(no auth)**

```
{
 "defaultMode": "system",
 "fallbackCode": "en",
 "en": { "menuLabel": "Language", "title": "Choose language" },
 "ar": { "menuLabel": "اللغة", "title": "اختر اللغة" },
 "languages": [
 {
 "code": "ar",
 "name": { "en": "Arabic", "ar": "العربية" },
 "nativeName": "العربية",
 "flag": "sa",
 "direction": "rtl"
 },
 {
 "code": "en",
 "name": { "en": "English", "ar": "الإنجليزية" },
 "nativeName": "English",
 "flag": "us",
 "direction": "ltr"
 }
]
}
```

### App logic

1. If the user already picked `ar` or `en`, use that.
  2. Else if the device language is `ar` or `en`, use that.
  3. Else use `fallbackCode` (`en`).
  4. Apply `direction` immediately (RTL for Arabic). No app restart.
  5. For every bilingual payload, read `.ar` or `.en`.
- 

## 7. Hamburger content (content-service, no auth)

Always return both languages. You pick one.

`GET /about`

Purpose, features list, mission. Optional `imageUrl`. Pick `en` or `ar`.

```
{
 "appVersion": "1.0.0",
 "imageUrl": null,
 "en": {
 "menuLabel": "About the App",
 "title": "About Murabba",
 "purposeTitle": "What is this app?",
 "purpose": "Murabba helps you explore what is around you.",
 "featuresTitle": "What can you do with it?",
 "features": ["Explore", "Share", "Connect"],
 "missionTitle": "Why was it built?",
 "mission": "Discover, share, and belong."
 },
 "ar": { }
}
```

#### GET /help

Categories + accordion items. Category/item `id` values are slugs and **match** across `en` / `ar` . Search and expand/collapse are frontend. If the request fails, show `emptyFallback` .

```
{
 "en": {
 "menuLabel": "Help Center",
 "title": "Help Center",
 "intro": "...",
 "emptyFallback": "Help is unavailable right now.",
 "contactCta": "Contact Us",
 "categories": [
 {
 "id": "account",
 "name": "Account",
 "items": [
 { "id": "reset-password", "question": "...", "answer": "..." }
]
 }
]
 },
 "ar": { }
}
```

#### GET /version

```
{
 "version": "1.0.0",
 "build": "20250707",
 "display": "v1.0.0 | Build 20250707",
 "channel": "production",
 "en": { "menuLabel": "App Version", "title": "App Version", "fallback": "Version: Unknown" },
 "ar": { "menuLabel": "إصدار التطبيق", "title": "إصدار التطبيق", "fallback": "الإصدار: غير معروف" }
}
```

Footer can still use native Info.plist / Gradle when offline. If the API fails, show `fallback` .

## Contact Us

GET /contact/types → includes ACCOUNT\_RECOVERY ( Account Recovery / استرجاع الحساب ) plus feedback, bug, feature, account issue, other.

POST /contact (normal types)

```
{
 "phone": "+96651234567",
 "email": "user@example.com",
 "title": "Cannot login",
 "type": "ACCOUNT_ISSUE",
 "message": "I cannot sign in with my phone number today.",
 "acceptedPrivacy": true
}
```

Phone **or** email (or both). Title 3–120. Message 20–256. Max 3 submits / 15 min per phone or email.

**201** { "id": "uuid", "message": { "en", "ar" }, "followUp": { "en", "ar" } }

## Recover Deleted Account (guest only — frontend hides this when logged in)

1. POST /contact/recovery/otp/start { "phone": "+96651234567" }
2. User enters 6-digit OTP (console if 4Jawaly empty on content-service)
3. POST /contact/recovery/otp/verify { "sessionId", "code" }
4. User writes message
5. POST /contact with type ACCOUNT\_RECOVERY + same phone + sessionId + message

OTP rules match auth: **2 min** TTL, **3** attempts → **5 min** lockout, resend after **30s**, max **3** resends.

### Start / resend 201

```
{
 "sessionId": "uuid",
 "expiresAt": "...",
 "resendAvailableAt": "...",
 "attemptsRemaining": 3
}
```

**Verify 201** { "sessionId": "uuid", "verified": true, "phone": "+96651234567" }

### Submit recovery

```
{
 "type": "ACCOUNT_RECOVERY",
 "phone": "+96651234567",
 "sessionId": "uuid-from-verify",
 "message": "I deleted my account by mistake and want it back please.",
 "acceptedPrivacy": true
}
```

- title optional (defaults to Account Recovery )

- `email` optional
- Phone + verified `sessionId` + message required
- Support reviews manually — there is **no** auto-restore API

UI: lock the type dropdown to Account Recovery; show Submitting... then thank-you from `message / followUp`.

## 8. Follow / followers / search (user-service, JWT)

Only **advertisers** (`isAdvertiser: true`) can be followed, appear in search, and have a Followers list.

Normal user:

- `followersCount` always `0`
- `showFollowers: false` → hide Followers tab (or show empty + lock)
- `canFollow: false` → never show Follow on their profile
- Following tab still lists **advertisers they follow**

`GET /users/:id`

```
{
 "id": "uuid",
 "username": "agent1",
 "displayName": "Ali Ahmed",
 "city": "Riyadh",
 "bio": null,
 "photoUrl": "/uploads/profiles/....jpg",
 "isAdvertiser": true,
 "isSelf": false,
 "isFollowing": false,
 "canFollow": true,
 "followersCount": 12,
 "followingCount": 4,
 "showFollowers": true,
 "canBeFollowed": true
}
```

| Flag                       | UI                      |
|----------------------------|-------------------------|
| <code>canFollow</code>     | show <b>Follow</b>      |
| <code>isFollowing</code>   | show <b>Unfollow</b>    |
| <code>isSelf</code>        | hide Follow; this is me |
| <code>showFollowers</code> | show Followers tab      |

No `phone` on this payload.

### Lists

GET /users/:id/followers?limit=20&offset=0

GET /users/:id/following?limit=20&offset=0

```
{
 "items": [
 {
 "id": "uuid",
 "username": "sara",
 "displayName": "Sara Ahmed",
 "photoUrl": null,
 "isAdvertiser": true,
 "followingCount": 2100,
 "isFollowing": true,
 "canFollow": false
 }
],
 "total": 1,
 "showFollowers": true
}
```

`followingCount` on a row is **how many advertisers that person follows** (Figma subtitle 2.1 K Following).  
Format 2100 → 2.1K on the client.

- Followers of a **normal** user: { "items": [], "total": 0, "showFollowers": false }
- Following: advertisers only, newest first
- On a row, if `canFollow` then Follow; if `isFollowing` then Unfollow; if neither (normal user in a followers list), hide the button

## Follow / unfollow

POST /users/:id/follow

DELETE /users/:id/follow

Both return the same profile object as `GET /users/:id`. Update the button from `canFollow` / `isFollowing` (optimistic UI is fine; rollback on error).

| Code               | HTTP |
|--------------------|------|
| FOLLOW_SELF        | 400  |
| FOLLOW_NOT_ALLOWED | 403  |
| USER_NOT_FOUND     | 404  |

Follow is idempotent. Unfollow is idempotent.

## Search & suggested (advertisers only)

GET /users/search?q=ali&limit=20&offset=0

GET /users/suggested?limit=20&offset=0

Same `items` + `total` shape as lists. Empty `q` → { "items": [], "total": 0 }.  
Normal users never appear.

---

## 9. Health

```
GET http://localhost:3000/health → { "status": "ok", "service": "user-service", "timestamp": "..."
}
GET http://localhost:3001/health → { "status": "ok", "service": "content-service", "timestamp":
"..." }
```

---

## curl cheat sheet

Replace tokens as needed. OTP code is in the **user-service console** when 4Jawaly is empty.

```
Username
curl "http://localhost:3000/users/username/available?username=Murabaa-1837"

Sign up
curl -X POST http://localhost:3000/auth/signup \
 -H "Content-Type: application/json" \
 -d "{\"phone\":\"+96651234567\",\"username\":\"Murabaa-1837\",\"acceptedTerms\":true}"

Verify OTP
curl -X POST http://localhost:3000/auth/otp/verify \
 -H "Content-Type: application/json" \
 -d "{\"sessionId\":\"SESSION_ID\",\"code\":\"123456\"}"

Me
curl http://localhost:3000/auth/me -H "Authorization: Bearer ACCESS_TOKEN"

Update profile
curl -X PATCH http://localhost:3000/auth/me \
 -H "Authorization: Bearer ACCESS_TOKEN" \
 -H "Content-Type: application/json" \
 -d "{\"displayName\":\"Mohammed Ahmed\",\"city\":\"Riyadh\",\"bio\":\"Real estate expert helping
you find your dream home.\"}"

Photo
curl -X POST http://localhost:3000/auth/me/photo \
 -H "Authorization: Bearer ACCESS_TOKEN" \
 -F "photo=@./avatar.jpg"

Language / About / Help / Version
curl http://localhost:3001/languages
curl http://localhost:3001/about
curl http://localhost:3001/help
curl http://localhost:3001/version

Contact
curl http://localhost:3001/contact/types
curl -X POST http://localhost:3001/contact \
 -H "Content-Type: application/json" \
 -d "{\"phone\":\"+96651234567\",\"title\":\"Cannot
login\",\"type\":\"ACCOUNT_ISSUE\",\"message\":\"I cannot sign in with my phone number
today.\",\"acceptedPrivacy\":true}"
```

```
Recover deleted account (guest)
curl -X POST http://localhost:3001/contact/recovery/otp/start \
 -H "Content-Type: application/json" \
 -d '{"phone\":"'+96651234567\'}"
curl -X POST http://localhost:3001/contact/recovery/otp/verify \
 -H "Content-Type: application/json" \
 -d '{"sessionId\":"SESSION_ID\","code\":"123456\'}"
curl -X POST http://localhost:3001/contact \
 -H "Content-Type: application/json" \
 -d "
{\'type\":"ACCOUNT_RECOVERY\","phone\":"'+96651234567\","sessionId\":"SESSION_ID\","message\":"
:I deleted my account by mistake and want it back please.\","acceptedPrivacy\:true\'}"

Profile + follow
curl http://localhost:3000/users/USER_ID -H "Authorization: Bearer ACCESS_TOKEN"
curl http://localhost:3000/users/USER_ID/following -H "Authorization: Bearer ACCESS_TOKEN"
curl -X POST http://localhost:3000/users/USER_ID/follow -H "Authorization: Bearer ACCESS_TOKEN"
curl -X DELETE http://localhost:3000/users/USER_ID/follow -H "Authorization: Bearer ACCESS_TOKEN"
curl "http://localhost:3000/users/search?q=ali" -H "Authorization: Bearer ACCESS_TOKEN"

Logout / delete
curl -X POST http://localhost:3000/auth/logout -H "Authorization: Bearer ACCESS_TOKEN"
curl -X DELETE http://localhost:3000/auth/account -H "Authorization: Bearer ACCESS_TOKEN"

Admin CMS examples (content-service – not for the mobile app)
curl http://localhost:3001/admin/about -H "x-admin-key: metr-dev-admin-key"
curl http://localhost:3001/admin/help-categories -H "x-admin-key: metr-dev-admin-key"
curl http://localhost:3001/admin/versions -H "x-admin-key: metr-dev-admin-key"
curl http://localhost:3001/admin/languages -H "x-admin-key: metr-dev-admin-key"
curl http://localhost:3001/admin/contact-types -H "x-admin-key: metr-dev-admin-key"
```

## 10. Admin CMS (content-service)

Header: `x-admin-key: metr-dev-admin-key` (from content-service `.env` `ADMIN_API_KEY`).

Not for the mobile app.

| Resource              | Collection URL                      |
|-----------------------|-------------------------------------|
| About pages           | <code>/admin/about</code>           |
| Help chrome           | <code>/admin/help-pages</code>      |
| Help categories       | <code>/admin/help-categories</code> |
| Help Q&A              | <code>/admin/help-items</code>      |
| Versions              | <code>/admin/versions</code>        |
| Languages (options)   | <code>/admin/languages</code>       |
| Language sheet labels | <code>/admin/language-pages</code>  |
| Contact types         | <code>/admin/contact-types</code>   |

Each supports GET list, GET /:id, POST, PATCH /:id, DELETE /:id.

Public GETs read the **active** About / Help / Version row. If version is missing in DB, content-service uses APP\_VERSION / APP\_BUILD / APP\_CHANNEL from .env.

### Error codes (user-service)

| Code                                              | HTTP                    |
|---------------------------------------------------|-------------------------|
| USERNAME_INVALID                                  | 400                     |
| USERNAME_TAKEN                                    | 409                     |
| PHONE_NOT_REGISTERED                              | 404                     |
| PHONE_ALREADY_REGISTERED                          | 409                     |
| TERMS_REQUIRED                                    | 400                     |
| SESSION_NOT_FOUND                                 | 404                     |
| OTP_INVALID                                       | 400 + attemptsRemaining |
| OTP_EXPIRED                                       | 400                     |
| OTP_LOCKED                                        | 429 + lockedUntil       |
| OTP_RESEND_COOLDOWN                               | 429 + resendAvailableAt |
| OTP_RESEND_LIMIT                                  | 429                     |
| PHOTO_REQUIRED / PHOTO_INVALID / PHOTO_TOO_LARGE  | 400                     |
| DISPLAY_NAME_INVALID / CITY_INVALID / BIO_INVALID | 400                     |
| USER_NOT_FOUND                                    | 404                     |
| FOLLOW_SELF                                       | 400                     |
| FOLLOW_NOT_ALLOWED                                | 403                     |
| missing/invalid JWT                               | 401 (Nest default)      |

### Error codes (content-service)

| Code                                                                 | HTTP |
|----------------------------------------------------------------------|------|
| CONTACT_PHONE_OR_EMAIL_REQUIRED                                      | 400  |
| CONTACT_PHONE_REQUIRED                                               | 400  |
| PHONE_INVALID / EMAIL_INVALID / TITLE_INVALID / CONTACT_TYPE_INVALID | 400  |
| MESSAGE_TOO_SHORT / MESSAGE_TOO_LONG / PRIVACY_REQUIRED              | 400  |
| RECOVERY_OTP_REQUIRED / RECOVERY_OTP_NOT_VERIFIED                    | 400  |
| SESSION_NOT_FOUND                                                    | 404  |

| Code                 | HTTP                    |
|----------------------|-------------------------|
| OTP_INVALID          | 400 + attemptsRemaining |
| OTP_EXPIRED          | 400                     |
| OTP_LOCKED           | 429 + lockedUntil       |
| OTP_RESEND_COOLDOWN  | 429 + resendAvailableAt |
| OTP_RESEND_LIMIT     | 429                     |
| CONTACT_RATE_LIMITED | 429                     |
| ADMIN_UNAUTHORIZED   | 401                     |
| CONTENT_NOT_FOUND    | 404                     |
| CONTENT_CONFLICT     | 409                     |

## Postman

Import `postman/Metr-API.postman_collection.json` .

1. Set `userBaseUrl` / `contentBaseUrl` .
2. Run **Sign up** → copy OTP from the user-service terminal into `otpCode` .
3. Run **Verify OTP** (saves `accessToken` ).
4. Run Me / Profile / Follow / Content requests.